

Fiche de Révision Active Directory

1.1.1 : Introduction des principales fonctions d'AD

Fonctions principales d'AD

- **Authentification** : Gère l'identité des utilisateurs pour permettre ou interdire l'accès aux ressources. Cela repose principalement sur des protocoles comme **Kerberos**.
- **Gestion des identités** : Centralise les informations (nom, mot de passe, email, etc.) et les droits associés à chaque objet (utilisateur, ordinateur).
- **Gestion des systèmes** : Applique des politiques sur les ordinateurs via des stratégies de groupe (GPO).

Tip

AD permet une **gestion centralisée** des identités, ressources, et politiques sur un réseau, facilitant l'administration à grande échelle.

Pourquoi utiliser Active Directory ?

- Connexion unique (SSO) : Un seul identifiant pour accéder à tout.
- Accès simplifié aux applications et fichiers.
- Personnalisation automatique de l'environnement utilisateur (bureau, lecteurs réseau, imprimantes).

Répertoire et identité

- Active Directory stocke les informations comme le nom, le mot de passe, le téléphone, l'adresse email.
- Ces données sont gérées par des **contrôleurs de domaine (DC)**, qui sont des serveurs assurant l'authentification et la gestion des objets.

Clarification des acronymes

- **AD DS** : Domain Services – service principal, gère les identités et les objets.
- **AD LDS** : Lightweight Directory Services – version allégée, sans gestion de domaine ni authentification Kerberos.
- **AD CS** : Certificate Services – pour émettre des certificats numériques (authentification, chiffrement).
- **AD FS** : Federation Services – authentification entre plusieurs domaines ou organisations.
- **AD RMS** : Rights Management Services – contrôle l'accès aux données (restrictions sur fichiers/documents).

Note

Chaque service a un rôle bien défini dans l'écosystème Active Directory.

❌ Idées reçues

⚠ Warning

- "Rien n'est standard, tout est personnalisé." (FAUX : des standards existent pour la plupart des configurations.)
- "C'est seulement pour Windows." (FAUX : AD peut interagir avec Linux ou des services cloud.)
- "C'est juste un gros serveur LDAP." (FAUX : LDAP est un protocole ; AD est une solution complète de gestion d'identités.)

1.1.2 : Fondamentaux de l'architecture AD

🧠 Modèle logique

Forêt > Domaines > Unités d'organisation (OU)

- **Forêt** : Ensemble de domaines partageant un schéma commun. C'est la limite maximale logique d'une instance AD.
- **Domaine** : Limite administrative et de sécurité. Contient les objets (utilisateurs, ordinateurs, etc.).
- **OU** : Organisation logique d'objets. Permet d'appliquer des GPO et de déléguer des permissions.

🌳 Topologie des sites AD

- Représente la structure physique du réseau (bureaux distants, sites).
- Sert à optimiser la réplication AD selon la géographie et la bande passante disponible.

Sites AD, DC, Sous-réseaux, Liens de sites, Ponts de liens : ces éléments forment la topologie de réplication.

🛡 Contrôleurs de domaine

- **RWDC** : Lecture/écriture complète. Autorise toute modification dans AD.
- **RODC** : Lecture seule. Utilisé en environnement peu sécurisé. Ne stocke pas les mots de passe par défaut.

🌱 Types d'objets

- Utilisateurs, groupes, ordinateurs, GPO, OU : tous sont des objets AD ayant des attributs.

🧱 Contextes de nommage

💡 Important

Chaque contexte détermine la **portée de réplication** (forêt, domaine, DNS). Ex : les objets utilisateurs ne sont répliqués que dans leur domaine.

Catalogue global

- Contient une copie partielle mais lisible de tous les objets AD de la forêt.
- Nécessaire pour localiser des objets dans toute la forêt, surtout pour les connexions inter-domaines.

Résolution de noms

Note

Le **DNS** est **essentiel** pour qu'AD fonctionne correctement : il permet de trouver les DCs.

Cycle de vie des objets

Objet supprimé → "Deleted Objects" (durée : 60 à 180 jours).

Warning

Au-delà du `tombstoneLifetime`, l'objet ne peut plus être restauré, car supprimé définitivement.

Principaux de sécurité (principals)

- Utilisateurs, groupes, ordinateurs sont des **objets de sécurité** identifiés par un **SID** unique.

(K) objectSID

SID = SID du domaine + RID
RID < 1000 → objets bien connus (ex : Administrateur).

Valeurs UAC (UserAccountControl)

Tip

Drapeaux activés/désactivés :

- Compte activé/désactivé
- Mot de passe expirant
- Authentification limitée à DES (obsolète)

Ordinateurs dans AD

- Ont un `sAMAccountName` et un **SID**.

Note

Pour le SSO Windows, l'ordinateur **doit avoir un compte dans AD** afin de s'authentifier.

Groupes

- **Sécurité** : Attribution de permissions sur des ressources.
- **Distribution** : Pour les emails uniquement (Exchange).

Tip

Toujours affecter les droits aux **groupes**, pas aux utilisateurs directement. Bonne pratique de sécurité.

Relations de confiance

Note

Permettent l'**authentification entre domaines**. Indispensable dans les forêts multiples ou organisations différentes.

- Unidirectionnelle vs bidirectionnelle : dans un sens ou les deux.
- Transitive vs non-transitive : s'étend-elle automatiquement ?

Types de relations

- Forêt
- Externe
- Raccourci
- Royaume (interopérabilité avec Kerberos non Windows)

Objets de confiance de forêt

- Attribut **FTInfo** :
 - TopLevelName
 - TopLevelNameExclusion
 - DomainInfo

Sécurité des relations de confiance

Warning

- **Authentification sélective** : rien n'est autorisé sans configuration explicite.
- **Filtrage SID** : empêche l'élévation de privilèges via un SID forgé.

Haute disponibilité d'AD

- Réplication **multi-maître** (pas de DC principal unique).
- Réplication **basée sur l'état** : seules les modifications sont répliquées.

Important

Il faut **surveiller la répllication** pour assurer l'intégrité des données entre DCs.

Topologie de réplication

Sites > Liens de sites > Sous-réseaux

- **Intra-site** : rapide (LAN)
- **Inter-site** : programmée et compressée (WAN)

KCC et ISTG

- **KCC** : Calcule la topologie de réplication (crée les connexions).
- **ISTG** : DC désigné pour gérer la topologie **inter-sites** (WAN).

1.1.3 : Intégration des machines dans AD

Étapes d'intégration

1. Préparer le poste (nom, configuration IP statique ou DHCP, groupe de travail).
2. Vérifier la résolution DNS (le poste doit pouvoir résoudre le nom du domaine AD).
3. Intégrer au domaine via l'interface graphique ou en PowerShell (`Add-Computer -DomainName "domaine.local"`).

Outils

- PowerShell : Automatisation des intégrations en masse, scripts de déploiement.
- Interface graphique : Utilisation manuelle, simple et visuelle.

Vérifications post-intégration

Tip

Toujours contrôler :

- Réponse aux pings DNS (nom du domaine et DCs).
- Entrée correcte dans les OU (via console AD).
- Appartenance confirmée dans les propriétés système.
- Synchronisation de l'heure (essentiel pour Kerberos).

1.1.4 : Authentification des comptes

Protocoles

- **Kerberos** : Utilisé par défaut. Authentification sécurisée basée sur des tickets. Nécessite synchronisation horaire.
- **NTLM** : Ancien protocole de type challenge/réponse. Utilisé en cas d'échec de Kerberos.
- **TLS/SSL** : Sécurisation des connexions LDAP.
- **Digest** : Obsolète, peu utilisé aujourd'hui.

Processus d'authentification

1. Le client envoie une requête d'accès à une ressource protégée.
2. Le DC vérifie l'identité via le protocole (Kerberos ou NTLM).
3. Si tout est bon, un **token d'accès** est fourni, contenant les droits et groupes de l'utilisateur.

Gestion des mots de passe

- Politique de complexité (longueur minimale, caractères spéciaux, etc.).
- Réinitialisation obligatoire périodique.
- Comptes verrouillés après un certain nombre de tentatives échouées.

Warning

Une politique faible compromet la **sécurité globale du domaine**.

1.1.5 : Découverte des contrôleurs de domaine

Étapes

1. Le client interroge le serveur DNS configuré dans sa carte réseau.
2. Le DNS retourne une liste de contrôleurs de domaine disponibles (via des enregistrements SRV).
3. Le client sélectionne le DC le plus approprié selon la **topologie de site**.

Rôle du DNS

- Chaque DC s'enregistre dans le DNS avec des enregistrements de type **SRV**.
- Les zones DNS AD doivent être **intégrées à AD** et **répliquées entre tous les DCs**.
- Sans DNS fonctionnel, **l'authentification échoue**.

1.1.6 : Gestion des objets

Tâches principales

- Créer : utilisateurs ([New-ADUser](#)), ordinateurs, groupes.
- Modifier : mise à jour des attributs (email, téléphone, service, etc.).
- Supprimer : suppression des comptes obsolètes.
- Déplacement : d'un objet vers une autre OU.

Outils utilisés

- **Centre d'administration Active Directory** : Interface graphique conviviale.
- **PowerShell** : pour automatiser la création/modification ([Set-ADComputer](#), [Move-ADObject](#), etc.).

Tip

Utilisez des **attributs personnalisés** (ex : code service, matricule) pour améliorer le filtrage ou les GPO ciblées.

1.1.7 : Contrôle d'accès dans AD

ACL (Listes de contrôle d'accès)

- **DACL** (Discretionary ACL) : Liste les autorisations accordées/refusées à des SIDs.
- **SACL** (System ACL) : Liste ce qui est journalisé à des fins d'audit (ex : tentative d'accès).

Permissions

- **Affectées à des utilisateurs ou groupes.**
- Peuvent être **héritées** (OU parent) ou définies manuellement.

GPO (stratégies de groupe)

- Permettent de configurer :
 - Sécurité (mots de passe, verrouillage).
 - Paramètres logiciels (scripts, applications).
 - Restrictions (accès USB, pare-feu, etc.).
- Appliquées à : Sites / Domaines / OU.

Tip

Une **bonne hiérarchisation des OU** rend la gestion des GPO bien plus efficace.

1.1.8 : Administrateurs par défaut

Comptes intégrés

- **Administrateur** : Contrôle total sur l'environnement AD. À sécuriser fortement.
- **Invité** : Très limité, souvent désactivé par défaut.

Groupes intégrés

- **Administrateurs du domaine** : Droits complets sur tout le domaine.
- **Utilisateurs du domaine** : Droits standards.
- **Opérateurs de compte, Opérateurs de serveur**, etc. : Groupes à rôles spécifiques.

Warning

Ne jamais ajouter un utilisateur lambda dans **Administrateurs du domaine** sans justification claire et besoin précis.

1.1.9 : Utilisation du protocole LDAP

Qu'est-ce que LDAP ?

- Protocole standard d'interrogation/modification d'annuaires (RFC 4511).
- Utilisé par Active Directory pour permettre aux clients d'accéder aux objets et attributs AD.

Requêtes LDAP

- Syntaxe : `(&(objectClass=user)(sAMAccountName=jdoe))` — récupère l'utilisateur `jdoe`.
- Le résultat est un **DN (Distinguished Name)** : chemin unique vers l'objet.

Outils LDAP

- **Ldp.exe** : Outil Microsoft pour tester les connexions et requêtes LDAP.
- **Clients LDAP graphiques** : Ex : Apache Directory Studio.
- **Scripts personnalisés** : Utilisation de Python, PowerShell, etc.

Tip

LDAP permet de connecter AD à des systèmes **non-Windows** (ex : Linux, applications web, services cloud).